* CASE STUDY (27/08/26)

Nidhi Rane
44010426075

* BrightMart is a medium-sized online shopping company; customers use its website and mobile application to purchase products.

The company stores:

- Customer names
- Email addresses
- Phone numbers
- Delivery addresses
- Passwords
- Order information
- Payment-related information

BrightMart has around 100 employes

The company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

Page No.
Date

However, the company has the following security weaknesses:

- Some employees use simple passwords such as ~~BrightMart~~ & BrightMart123.
- Many employees use the same password for multiple systems.

(More weaknesses on next page).

The Incident

One Monday morning, an employee named Rahul receives an email.

Subject:- Urgent- Your Account will be suspended

The email appears to come from the company's IT department.

It says:
"Your company account will be suspended today. Click the link below and verify your password immediately."
Rahul clicks the link.
The page looks ~~ads~~ almost identical to the company's login page.
He enters his username and password.
Rahul does not realize that the website is controled by an attacker.
The attacker now has Rahul's login credentials

Page No.
Date

~~Step 1 - Unauthorized Access~~

More weaknesses

- ~~Many~~ Software updates are sometimes delayed.
- The company does not regularly conduct employee cyber-security training.
- There is no MFA for some important accounts.
- Employees can access sensitive information that they do not necessarily need for their jobs.
- Backups are performed only once a month.

Step 1 - Unauthorized Access

The attacker uses Rahul's credentials to access Bright Mart's internal system.
Because ~~Rahul~~ Rahul uses the same password for another system, the ~~the~~ attacker is also ~~also~~ able to access that system.
The attacker ~~the~~ discovers that ~~Ra~~ Rahul ~~has~~ has access to customer data.

What cybersecurity problem has occured?

Stage 2 - Malware Attack

The attacker sends another email to Rahul containing a malicious attachment.
Rahul opens the attachment.
Malware is ~~a~~ installed on his computer.
The Malware begins communicating with the attacker's system.

The attacker now attempts to move from Rahul's computer to other systems with BrightMart's network.

Question
Which vulnerability allowed the attacker to move further into the organization?

Stage 3 - Ransomware

Two days later, employees arrive at work and discover that they cannot access important files. A message appears on their computers:
"Your files have been encrypted. Pay the ransom to recover them."
The company's customer database and several important business files are encrypted.
Unfortunately, the company's most recent backup is almost a month old.
BrightMart's website stops working.
Customers cannot place orders.
The customer - support team cannot access customer records.

Stage 4 - Business Impact

BrightMart now faces several problems
Financial Impact.
The company loses sales because its website is unavailable.

Page No.
Date

Data Impact
Customer information may have been stolen
Operational Impact
Employes cannot acces important systems.
Reputation Impact
Customers lose confidence in the company.
Legal / Compliance Impact.
The company may face regulatory or legal consequences depending on what information was exposed and which laws apply.

Questions & Answers.

What cybersecurity problem has occured?
→ • Phishing
• Credential theft
• Unauthorized access
• Data breach

Which vulnerability allowed the attacker to move further into organization?
→ • Weak passwords
• Excessive user privileges
• Lack of MFA
• Poor network security
• Lack of employee awareness
• Outdated software

Page No.
Date

Group 1 - Identify the Threats:
What threats are present in this case?

→
- Phishing
- Malware
- Ransomware
- Credential theft
- Unauthorized access
- Data theft

Group 2 - Identify the Vulnerabilities
What weaknesses in BrightMart's security allowed the attack to succeed?

→

Vulnerability	How it helped the attacker
• Weak passwords	– Easier to compromise accounts
• Password reuse	– One stolen password gives access to multiple systems.
• No MFA	– Stolen password may be enough to log in.
• Lack of training	– Employee fails for phishing
• Delayed updates	– Vulnerable software may be exploited.
• Excessive privileges	– Attacker can access more data.
• Infrequent backups	– Difficult to recover after ransomware.

Group 3: Apply CIA Triad
Was confidential information exposed? (Confidentiality)

→ Yes,
Customer information was accessed/downloaded by the attacker.

Was information changed or damaged? (Integrity)

→ Potentially yes,
The attacker could modify or encrypt files.

Were systems available to legitimate users? (Availability).

→ No.
The website and internal systems became unavailable because of ransomware

So,
confidentiality - Affected
Integrity - Affected
Availability - Affected.

Group 4 - Security solutions.
What should Bright do to prevent this from ~~happening~~ happening again?

→ • Use strong passwords
• Implement Multifactor Authentication (MFA)
• Provide regular cybersecurity awarenes training
• Conduct phishing - awareness exercises.
• Keep software ~~upter~~ updated.
• Follow the principle of least ~~privil~~ privilege.
• Segment import networks.
• Maintain regular backups.
• Encrypt sensitive data.
• ~~Dot~~ Deploy antivirus / endpoint protection.

- Monitor suspicious login activity.
- Develop an incident-response plan.

Question 1.

Who is responsible for cybersecurity?

→ Not only the IT Department. Every employee who uses the organisation's systems has a role in cybersecurity.

Question 2

Was phishing the only problem?

→ No.

Phishing was the initial attack, but weaknesses such as password reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attack to become much more damaging.

Question 3

What was the biggest vulnerability?

→ Lack of employee awareness was a major vulnerability because the attack started when Rahul clicked the phishing link.

OR

Poor backup practices were the biggest problem because BrightMart could not quickly recover from ransomware.

Both can be valid if properly justified.

There is no single correct answer.

Page No.
Date

Quick Assessment

1) What was the initial attack against BrightMart?

→ Phishing was the initial attack against BrightMart

2) Give three vulnerabilities that helped the attacker

→ • password reuse.
• Lack of MFA (Multi-Factor Authentication)
• Lack of employee cybersecurity training
are the vulnerabilities that helped the attacker.

3) Which three security principles of the CIA Triad were affected?

→ • Confidentiality → customer information was accessed / download.
• Integrity - files could be modified or encrypted.
• Availability - the website and internal systems became unavailable.

4) What was the impact of ransomware on BrightMart?

→ The ransomware made the website and internal system unavailable and could encrypt files, making it difficult for BrightMart to operate and recover.

5) Suggest three security controls BrightMart should implement.

Page No.
Date

→ • Implement Multi-Factor Authentication.
• provide regular cybersecurity awareness and phishing training.
• Maintain regular backups of important data.